

REPORTE DE VULNERABILIDAD

En este documento describo los hechos, hemos practicado una inyección SQL para probar si hay vulnerabilidades en el web.

Descripción del incidente

Usando DVWA se descubrió una vulnerabilidad al practicar una inyección de sql. Nos ha permitido hacer consultas a través de los campos de entrada del web. Nos da datos **confidenciales** de los usuarios que normalmente no deberían ser visibles para cualquiera.

Reproducción del proceso - inyección SQL

Para demostrar la vulnerabilidad nos hemos dirigido a la casilla "User ID" y hemos cargado lo siguiente:

1 1' OR '1' = '1

La pagina ha devuelto:

***ID: 1 1' OR '1' = '1 First name: admin Surname: admin
ID: 1 1' OR '1' = '1 First name: Gordon Surname: Brown
ID: 1 1' OR '1' = '1 First name: Hack Surname: Me
ID: 1 1' OR '1' = '1 First name: Pablo Surname: Picasso
ID: 1 1' OR '1' = '1 First name: Bob Surname: Smith***

Impacto del incidente

Han quedado comprometidos datos que pueden servirle al atacante para seguir indagando y accediendo a más datos, que puede llegar a borrar o modificar

Recomendaciones

- Validación de entrada: Mejorarla para que sea más estricta con los datos proporcionados utilizando parámetros más seguros en las consultas SQL.
- Pentesting (Pruebas de penetración) Realizar pruebas de seguridad periódicamente para que estos fallos sean detectados y solventados lo antes posible.
- Formación: Capacitar al personal, tanto técnico como el resto de usuarios para que conozcan los peligros de las vulnerabilidades y tomen conciencia.

Conclusión

Con esta inyección dejamos a la vista la importancia de ser constantes a la hora de hacer del web un sitio seguro, a través de mantenimiento, pruebas de seguridad...